

F24-D-001-ProbeXpert

Project Team

Usman Naeem	21I-1560
Mahareeb Fatima	21I-1564
Muhammad Faheem	21I-1910

Session 2021-2025

Supervised by

Dr. Muhammad Asim

Co-Supervised by

Mr. Irfan Ullah



Department of Computer Science

**National University of Computer and Emerging Sciences
Islamabad, Pakistan**

June, 2025

Contents

1	Introduction	1
1.1	Problem Statement	1
1.2	Scope	1
1.3	Modules	2
1.3.1	External Asset Scanning	2
1.3.2	Risk Factor Calculation & Vulnerability Assessment	2
1.3.3	Real-Time Progress Tracking	2
1.3.4	Reporting	3
1.4	User Classes and Characteristics	4
2	Project Requirements	5
2.1	Use-case/Event Response Table/Storyboarding	5
2.1.1	High-Level Use Cases	5
2.1.2	Extended Use Cases	6
2.1.3	Event Response Table	12
2.2	Functional Requirements	14
2.2.1	Module 1: External Asset Scanning	14
2.2.2	Module 2: Risk Factor Calculations & Vulnerability Detection	14
2.2.3	Module 3: Real-Time Progress Tracking	14
2.2.4	Module 4: Reporting	15
2.3	Non-Functional Requirements	15
2.3.1	Reliability	15
2.3.2	Readability	15
2.3.3	Usability	16
2.3.4	Performance	16
2.3.5	Security	16
2.4	Domain Model	17
3	System Overview	19
3.1	Architectural Design	19
3.1.1	Modules	20
3.1.2	Initial Design	21
3.1.3	Final Architecture Diagram	22

3.2	Design Models	22
3.2.1	Activity Diagrams	22
3.2.2	Data Flow Diagrams	25
3.2.3	System Sequence diagrams	31
3.2.4	State Transition Diagram	32
3.2.5	Entity Relation Diagram (ERD) of ProbeXpert	34
3.3	Data Design	35
3.3.1	Information Domain Transformation	35
3.3.2	Major Data/System Entities	35
3.3.3	Data Storage Items	36
	References	37

List of Figures

2.1	Use case diagram of ProbeXpert.	11
2.2	Domain Model of ProbeXpert	17
3.1	Initial design of ProbeXpert	21
3.2	Final architecture diagram of ProbeXpert	22
3.3	Activity diagram of End-User	23
3.4	Activity diagram of System Admin	24
3.5	DFD Level-0 of ProbeXpert	25
3.6	DFD Level-1 of ProbeXpert	26
3.7	DFD Level-2 of External asset scanning.	27
3.8	DFD Level-2 of Risk factor calculation.	28
3.9	DFD Level-2 of Real-time progress tracking.	29
3.10	DFD Level-2 of Report generation	30
3.11	System sequence diagram of End-User	31
3.12	System sequence diagram of System Admin	32
3.13	State transition diagram of ProbeXpert	33
3.14	Entity Relationship Diagram of ProbeXpert	34

List of Tables

1.1	High-level use cases of ProbeXpert.	4
2.1	Usecase: UC-01	5
2.2	Usecase: UC-02	5
2.3	Usecase: UC-03	6
2.4	Usecase: UC-04	6
2.5	Extended usecase: EUC-01	6
2.6	Extended usecase: EUC-02	8
2.7	Event response table of ProbeXpert	12

Chapter 1

Introduction

This document offers an automated method for conducting external scans, vulnerability assessments, and risk management tailored for enterprises with limited resources. It outlines the main characteristics of the system, including user-friendly tools and customizable scanning, as well as automated reporting, to streamline and improve cybersecurity tasks.

1.1 Problem Statement

The cybersecurity environment constantly evolves, making it challenging for many organizations to keep pace. Small to medium-sized enterprises lack the resources and expertise to implement efficient security controls, hence a gap in their security policies. Organizations struggle to safeguard their external assets due to the complexity, cost, and resource-intensive nature of existing external scanning and vulnerability assessment solutions.

1.2 Scope

ProbeXpert aims to create an automated, web-based platform for external asset scanning, vulnerability assessment, and compliance reporting for SMEs. Its goal is to simplify cybersecurity management for organizations that lack resources. Key features include automated external scanning, real-time progress tracking, IP reputation evaluation, and self-healing architecture. It generates risk assessments and compliance reports from identified vulnerabilities, with dynamic updates as new risks emerge. Its design is scalable, and ProbeXpert concentrates solely on external threats and does not cover internal monitoring and intrusion detection.

1.3 Modules

1.3.1 External Asset Scanning

This module automates the scanning of publicly accessible assets, such as IP addresses and domain names, to identify potential vulnerabilities. It enables businesses to secure their external digital presence without requiring extensive manual intervention.

1. Automated Scanning: Initiates On-demand scans of external systems to detect vulnerabilities.
2. Customizable Scan Parameters: Allows users to select from 3 scan types; i.e. Deep scan, Shallow Scan, and Individual scan. Users can add or remove the tools of their choice in these scans.

1.3.2 Risk Factor Calculation & Vulnerability Assessment

This module calculates the risk factors for each vulnerability, prioritizing them based on environmental variables, network characteristics, and exploitability [1]. It ensures that the most crucial vulnerabilities are addressed first by assigning risk values that consider the severity of the vulnerability and the context in which it resides.

1. Environmental Variables Analysis: Incorporates network-specific variables (e.g., open ports, total vulnerabilities, average organization risk) into the risk assessment to tailor the risk score for each vulnerability based on its environment.
2. Risk Factor Calculation: Calculates the risk factor by considering the probability of occurrence and impact, using factors such as the number of vulnerabilities, open ports, and exploitation likelihood.
3. Quantitative Score Categorization: Assigns risk levels to identified vulnerabilities based on severity, likelihood, and impact.
4. Prioritization of Vulnerabilities: Assign a priority ranking to each vulnerability by calculating a composite score that reflects both the vulnerability's severity and the environmental factors.

1.3.3 Real-Time Progress Tracking

This module monitors the progress of scans and vulnerability assessments in real-time, giving users continuous updates on the status and performance of ongoing security oper-

ations. It enhances user engagement by providing clear, actionable insights as scans are conducted.

1. **Live Scan Results:** Displays real-time progress of active scans, including percentage completion and time remaining.
2. **Alerts and Notifications:** Sends alerts for completed scans, allowing users to take immediate action on detected vulnerabilities.
3. **Estimated Time of Completion:** Offers estimated times for scan completion based on current progress and scan size, helping users manage their time more effectively.

1.3.4 Reporting

The reporting module is responsible for generating detailed reports based on the results of vulnerability scans and risk assessments. These reports provide valuable insights for compliance, risk management, and decision-making.

1. **Detailed Vulnerability Reports:** Includes comprehensive information on identified vulnerabilities, including severity, risk factors, and prioritization table.[\[1\]](#)
2. **Risk Score Visualization:** Includes graphical representations of vulnerability risk scores, making it easier for non-technical stakeholders to interpret the data.
3. **Risk Summary:** Provides an executive summary of the overall security posture, including risk levels and top vulnerabilities.
4. **Exportable Format:** Provides the option to export reports in PDF format, allowing for easy sharing with stakeholders and ensuring compatibility for documentation and compliance purposes.

1.4 User Classes and Characteristics

Different user classes are expected to interact with ProbeXpert, each with unique characteristics and requirements.

Table 1.1: High-level use cases of ProbeXpert.

User class	Description
System Administrator	The responsibilities of the System Administrator include managing and configuring the platform, setting up scans, pushing new plugins, managing user access, and maintaining the system's smooth operation. They possess high-level technical expertise and familiarity with cyber security tools, employing the platform frequently to oversee security operations and address vulnerabilities.
System	The system interacts with external and Internal APIs to gather data, ensures plugin stability and version tracking (enabling reverting to safe versions), and automates routine scans. It guarantees access to the most recent tools and updates, while also upholding platform security and data integrity.
Website User	Website User manages the organization's infrastructure, performs personal scans of external assets using the platform, and responds to vulnerabilities detected by the system. Although they frequently interact with the system by reviewing scan results and assessing potential risks, they depend on security experts or specialized staff members for thorough analysis and addressing complex vulnerabilities. Their role involves starting scans and conducting fundamental analysis.

Chapter 2

Project Requirements

This chapter describes the functional and non-functional requirements of the project.

2.1 Use-case/Event Response Table/Storyboarding

2.1.1 High-Level Use Cases

Table 2.1: Usecase: UC-01

ID	UC-01
Use Case	Scanning
Actor	Website User
Type	Primary
Description	The website user enters the domain to initiate the scanning procedure. The scanning mechanism targets four sections: database, end-point security, patching cadence, and cubit score.

Table 2.2: Usecase: UC-02

ID	UC-02
Use Case	View Scanning Status
Actor	Website User
Type	Primary
Description	As the domain scanning can take some time to complete, during that time the user can view the estimated time remaining, a status bar of the percentage of completion, and display a message once completed.

Table 2.3: Usecase: UC-03

ID	UC-03
Use Case	View Vulnerability Report
Actor	Website User
Type	Primary
Description	Once the domain scanning has been completed, the website user can view all the vulnerabilities detected by the system in a proper report form generated in pdf form.

Table 2.4: Usecase: UC-04

ID	UC-04
Use Case	Manage plugins repository & bundles
Actor	System Administrator
Type	Primary
Description	The System Administrator can upload, install, and activate new plugins to extend the system's functionality. This may include plugins for scanning tools, reporting features, or security modules. The administrator will verify plugin integrity and compatibility before deployment.

2.1.2 Extended Use Cases

Table 2.5: Extended usecase: EUC-01

Use Case ID	EUC-01
Use Case Name	Scanning External Assets for Vulnerabilities
Scope	ProbeXpert (External Asset Scanning Module)
Primary Actor	Website User
Secondary Actor	System
Stakeholders & Interests	• End-User: Wants to initiate a scan on external assets without the need for technical expertise. • IT Security Staff: Needs to monitor and assess external systems for vulnerabilities regularly. • Organization: Aims to protect external assets and mitigate potential risks through vulnerability detection.

Trigger	The end user or IT Security Staff initiates a scan of external assets by entering a domain or IP address.
Preconditions	• The user has a valid account and is logged into the system. • The user has the necessary permissions to initiate a scan. • The external assets (IP address or domain) are accessible by the system.
Post Conditions	• The scan is successfully initiated. • The system stores the scan parameters and generates a list of detected vulnerabilities. • Scan progress is updated and displayed to the user in real-time.
Success Guarantee	The system successfully initiates the scan, processes the results, and provides a detailed list of vulnerabilities for further action.
Normal Path	1. The user logs into the system. 2. Navigate to the "External Asset Scanning" page. 3. Enters the IP address or domain name to be scanned. 4. Select the scan type (Deep, Shallow, or Individual) and custom tools. 5. Confirm the scan. 6. The system initiates the scan, displays real-time progress, and sends an alert upon completion. 7. The scan results are saved in the system, and a summary of vulnerabilities is displayed. 8. Detailed scan results are compiled in a pdf report and ready for download.
Alternative Path	If the scan fails due to invalid input (e.g., wrong IP address format or unreachable domain), the system displays an error message. The user is prompted to correct the input and retry.
Extension	• If the scan exceeds a predefined time limit, the system sends an alert to the user and provides an option to either extend the time or terminate the scan. • If a new plugin or tool is available for scanning, the system will notify the user, allowing them to update the scan settings with the new tools.

Special Requirements	• The system must support various scan types (Deep, Shallow, Individual). • The system must be able to handle large-scale scans for multiple external assets simultaneously. • Must provide real-time updates on scan progress and completion estimates.
Technology and Data Variation List	Scan results are processed by Docker-based worker nodes and stored in a No-SQL database (e.g., MongoDB). The user interface displays scan results via a web interface.
Frequency of Occurrence	Performed as required, typically during routine security audits or when monitoring new external assets.

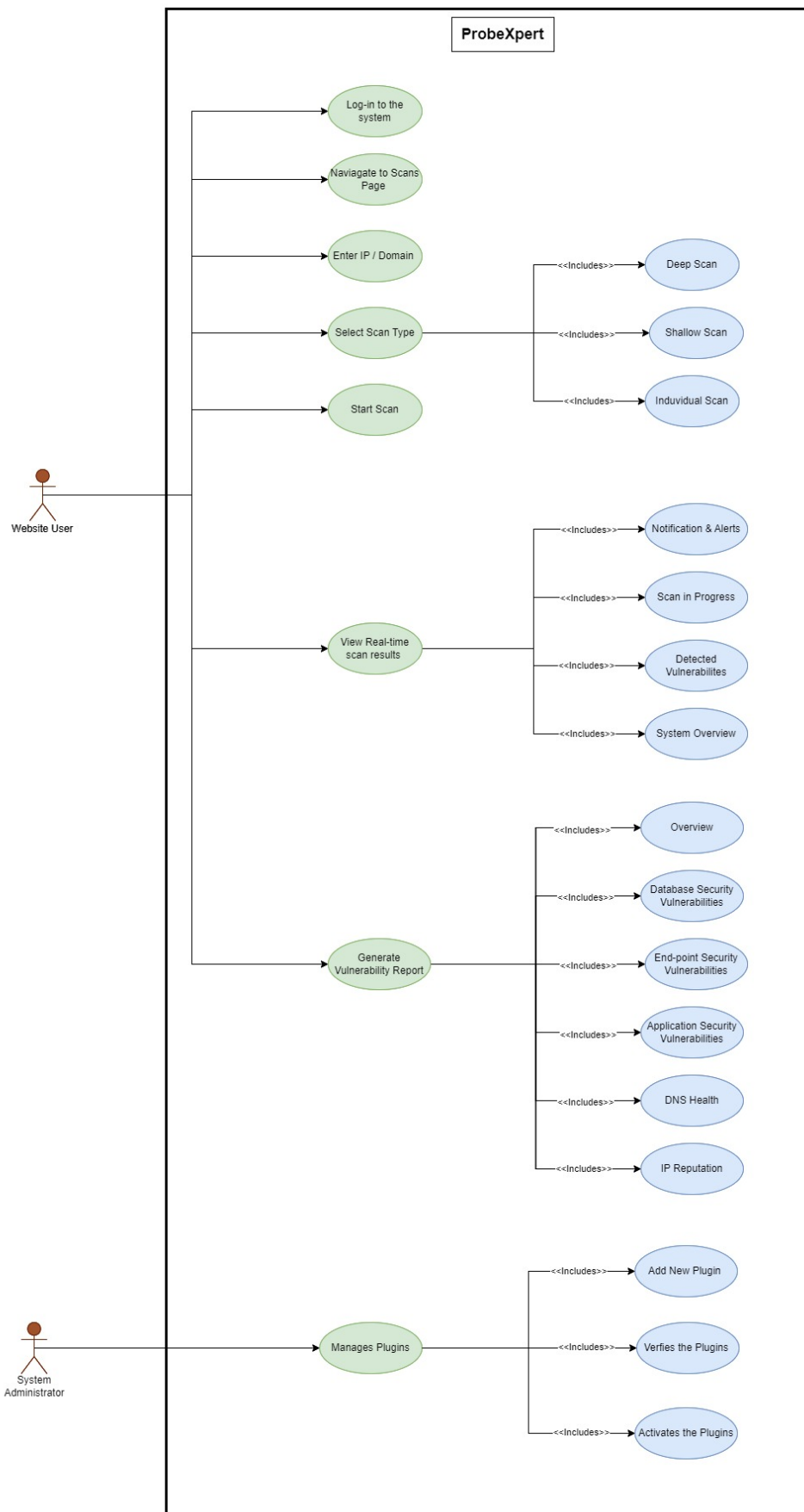
Table 2.6: Extended usecase: EUC-02

Use Case ID	EUC-02
Use Case Name	Manage Plugins Repository & Bundles
Scope	ProbeXpert (Plugins Management Module)
Primary Actor	System Administrator
Secondary Actor	System
Stakeholders & Interests	• System Administrator: Wants to upload, install, and activate plugins to enhance the system's functionality (scanning tools, reporting, etc.). • Organization: Requires the system to stay updated with the latest security scanning tools and features for comprehensive vulnerability assessments.
Trigger	The System Administrator needs to add a new plugin or update an existing one to enhance or extend system functionality.
Preconditions	• The System Administrator is logged into the system with the necessary permissions.

	• The system is connected to a valid plugin repository, or the administrator has access to plugin files. • Plugin files must be in a compatible format and structure for the system.
Post Conditions	• The plugin is successfully uploaded, verified, and activated. • The system stores the scan parameters and generates a list of detected vulnerabilities. • The plugin repository is updated with the new plugin data.
Success Guarantee	The plugin is successfully uploaded, installed, and activated without issues, extending the system's functionality.
Normal Path	1. The System Administrator logs into the system. 2. Navigates to the "Manage Plugins Repository" page. 3. Uploads the new plugin file or selects it from the repository. 4. The system verifies the plugin's integrity and compatibility. 5. Upon successful verification, the system installs the plugin. 6. The administrator activates the plugin. 7. The system updates the list of available tools and confirms the plugin installation. 8. The system displays a success message, indicating that the plugin is active.
Alternative Path	• If the plugin fails verification (e.g., due to incompatibility or corrupted file), the system rejects the plugin and displays an error message. • The administrator can choose to fix the issue and retry the upload or contact support for assistance.

Extension	• If a plugin update is available, the system notifies the administrator, allowing them to update existing plugins without removing previous versions. • If a plugin requires additional configurations (e.g., network settings), the system prompts the administrator to complete the necessary setup before activation.
Special Requirements	• The system must support different plugin types (scanning tools, reporting features, security modules). • Must provide plugin version control and rollback options. • Ensure plugin verification is secure and prevents malicious uploads.
Technology and Data Variation List	• Plugins are uploaded via a web interface and stored in a dedicated file repository. The system processes plugin metadata and configurations in JSON format. • Docker is used to sandbox and run the plugin, ensuring isolation and security.
Frequency of Occurrence	Performed as needed, typically when new functionality is required or during system maintenance and updates.

Figure 2.1: Use case diagram of ProbeXpert.



2.1.3 Event Response Table

Table 2.7: Event response table of ProbeXpert

Event	Source of Event	Precondition	Response	Post Condition
System Administrator logs into the system.	System Administrator	Administrator has valid credentials and permissions.	The system authenticates the administrator.	Administrator logged in successfully.
Navigate to the "Manage Plugins Repository" page	System Administrator	Administrator is logged into the system.	The system loads the Plugins Repository page.	The administrator can view and manage plugins.
Upload a new plugin or select from the repository	System Administrator	Administrator has access to a valid plugin file or repository.	The system uploads the plugin or fetches it from the repository.	Plugin is submitted for verification.
Plugin verification	System (automated)	Plugin file is uploaded or selected.	The system checks the plugin for integrity, compatibility, and security (e.g., scanning for malware).	Plugin is verified or rejected with an error message.
Plugin installation	System	Plugin successfully verified.	The system installs the plugin in the appropriate Docker environment for isolation.	Plugin is installed and ready for activation.
Plugin activation	System Administrator	Plugin installed successfully.	The administrator activates the plugin via the system interface.	Plugin is active, and system tools are updated.
System update with new tools and functionality	System (automated)	Plugin has been activated.	The system updates the list of available scanning tools and functionalities.	Plugin repository and system tool list are updated.

Kubernetes rollback	System (auto-mated)	Plugin fails installation or operation.	Kubernetes rolls back to the previous safe plugin version.	System reverts to the previous working version.
Kubernetes restart	System (auto-mated)	Kubernetes instance crash detected.	Kubernetes automatically restarts the node in 1-2 seconds.	System recovers with minimal downtime.
Success message displayed	System (auto-mated)	Plugin installation and activation are complete.	The system displays a confirmation message indicating plugin activation success.	Administrator is notified of successful activation.
Plugin verification failure	System (auto-mated)	Plugin file fails verification (e.g., corrupted or incompatible).	The system rejects the plugin and displays an error message with details.	Administrator is notified of the failure and can retry or fix the issue.
Retry plugin upload	System Administrator	Plugin failed verification.	The administrator fixes the issue and retries the upload.	Plugin is re-submitted for verification.
Plugin update available	System (auto-mated)	Plugin update is available in the repository.	The system notifies the administrator and offers the option to update the existing plugin.	Administrator can choose to update the plugin, and the system begins the update process.
Additional configuration required	System (auto-mated)	Plugin requires network or custom configuration for full functionality.	The system prompts the administrator to complete additional configurations.	Administrator completes configurations, and the plugin is fully functional.

2.2 Functional Requirements

Following are the functional requirements of ProbeXpert:

2.2.1 Module 1: External Asset Scanning

Following are the requirements for module 1:

1. FR1: The user should be able to initiate on-demand scans on IP addresses and domain names.
2. FR2: There are three types of scans (Deep, Shallow, and Individual) that the user should be able to customize.
3. FR3: The users should be able to add or remove specific scanning tools to tailor the scan.
4. FR4: After the scan is completed, the system shall generate a list of detected vulnerabilities along with their severity levels.

2.2.2 Module 2: Risk Factor Calculations & Vulnerability Detection

Following are the requirements for module 2:

1. FR1: The system should be able to calculate the risk factor for each vulnerability based on various environmental variables (open ports, total vulnerabilities, etc.).
2. FR2: The system should be able to categorize vulnerabilities based on a quantitative score using severity, likelihood of exploitation, and impact.
3. FR3: The system should be able to prioritize vulnerabilities for the user, displaying the most critical ones first.
4. FR4: Users should be able to trigger a new scan to detect recently discovered vulnerabilities and update risk scores based on new vulnerabilities or environmental changes.

2.2.3 Module 3: Real-Time Progress Tracking

Following are the requirements for module 3:

1. FR1: The system should be able to provide real-time updates on the progress of active scans, showing percentage completion.
2. FR2: The system should be able to display estimated completion times for scans based on scan type and progress.
3. FR3: When the scans are completed or if an error occurs the system should be able to send alerts and notifications to users.

2.2.4 Module 4: Reporting

Following are the requirements for module 4:

1. FR1: The system should be able to generate detailed vulnerability reports, including risk factors.
2. FR2: The system should be able to offer risk score visualizations through graphs, like Bar charts, pie charts, and heat maps to view vulnerability severity graphically.
3. FR3: The system should be able to provide a summary of the organization's overall risk posture, highlighting top vulnerabilities.
4. FR4: The system should be able to allow users to export reports in PDF format for easy sharing.

2.3 Non-Functional Requirements

2.3.1 Reliability

1. REL-1: The system should guarantee that data integrity is preserved, and no scan results are lost in the event of a critical failure.

2.3.2 Readability

1. READ-1: Our report is made in such a way that every IT team member or even individuals with minimum IT knowledge can gather maximum information from it and understand it easily.

2.3.3 Usability

1. USE-1: The user interface shall provide tooltips and on-screen help for all major features to reduce the need for extensive training.
2. USE-2: The system shall provide feedback for user actions (e.g., starting scans, saving reports) within 2 seconds.
3. USE-3: The system shall include a built-in trained chatbot to answer user queries related to the system and external scanning.

2.3.4 Performance

1. PER-1: The system shall generate detailed reports for a completed scan within 10 seconds after the scan concludes.
2. PER-2: The system shall use Kubernetes for automatic load balancing to guarantee the best distribution of scan requests and resources among numerous containers, avoiding system overload and ensuring high availability during heavy loads.

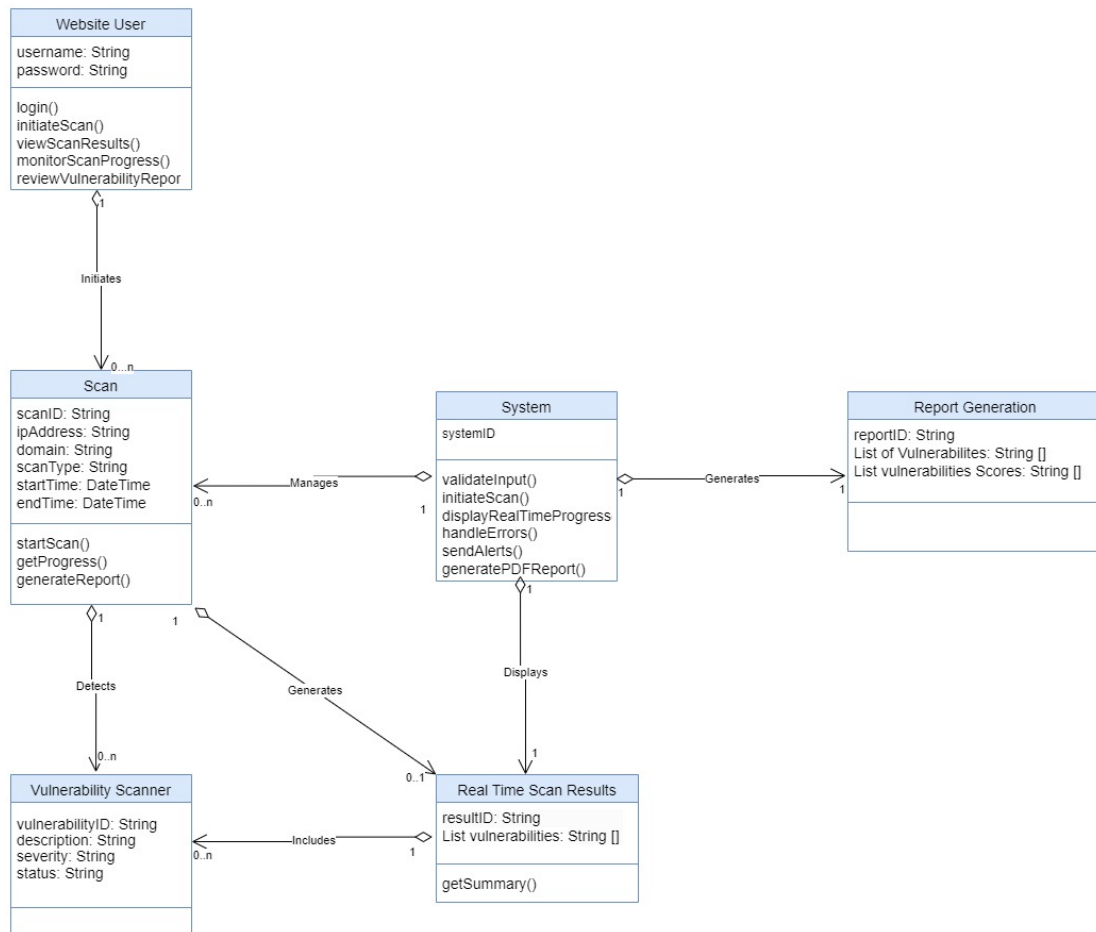
2.3.5 Security

1. SEC-1: The system must use role-based access control (RBAC) with a minimum of 3 user roles (e.g., Administrator, Analyst, Viewer) to avoid unauthorized access.
2. SEC-2: All services must operate independently in their own Docker containers within the system. If one service fails, it will not impact the functionality of other services, ensuring the system's ability to recover and isolate faults.

2.4 Domain Model

This diagram outlines the main objects in the system and their relationships. It details how a **Website User** interacts with **Scans** and the **System**, highlighting the management of scans and generation of vulnerability reports, showcasing the flow of data and control within the system.

Figure 2.2: Domain Model of ProbeXpert



Chapter 3

System Overview

ProbeXpert is an online platform created for small and medium-sized businesses to automate external asset scanning, vulnerability assessment, and compliance reporting. It tackles the issues of scarce IT resources and knowledge through a user-friendly interface that identifies and ranks vulnerabilities in assets like IP addresses and domains.

The system scans outside platforms, evaluates weaknesses using environmental and network factors, and determines which ones to fix first. It offers instant updates on scanning progress and creates thorough reports that can be saved in PDF for compliance needs.

ProbeXpert guarantees expandability and adaptability due to its modular design. Basic functions such as scanning, risk evaluation, and reporting work separately, with assistance from Kubernetes for distributing workloads and Docker containers for separating services. This design boosts dependability and guarantees the platform's efficiency and security, even during high traffic.

3.1 Architectural Design

The structure of ProbeXpert consists of four main components: External Asset Scanning Module, Risk Factor Calculation and Vulnerability Assessment Module, Real-Time Progress Tracking Module, and Reporting Module. Every module manages different functions yet works together to provide a smooth and effective vulnerability detection and reporting process.

3.1.1 Modules

Modules 1: Scanning external Assets

This module starts and controls the scanning procedure for external assets such as IP addresses and domain names. It allows users to conduct scans as needed, with adjustable parameters, offering a choice of scan types (Deep, Shallow, or Individual) and the ability to pick the tools for the scan. The results of the scan are examined and forwarded for additional processing.

Communications:

- i. The Flask handler coordinates requests and schedules scans, overseeing plugins and assigning tasks to Docker worker nodes for processing.
- ii. Receives analyzed scan findings from the Worker Nodes and sends them to the Risk Factor Calculation module for additional handling.
- iii. Gives scan status updates to the Real-Time Progress Tracking Module.

Module 2: Risk Factor Calculations & Vulnerability Detection

This module evaluates the scan findings using environmental factors such as open ports and vulnerability count and computes the risk scores. It categorizes vulnerabilities based on quantitative risk levels, considering severity, likelihood of exploitation, and impact on the network as factors.

Communications:

- i. Gets parsed scan results from the External Asset Scanning Module.
- ii. Utilizes enrichment worker nodes to process data for risk score calculation and to enhance the overall risk posture.
- iii. Share the results that have been enhanced and evaluated with the Reporting Module for creating reports.

Module 3: Real-Time Progress Tracking

The module for tracking progress in real-time keeps a constant watch on the ongoing scans. Users are given real-time updates, such as completion percentage, time left estimates, and scan reports. Notifications and alerts are triggered upon completion of scans or in case of errors.

Communications:

- i. Consistently interacts with the External Asset Scanning Module and the Risk Factor Calculation Module to obtain the most recent updates and progress metrics.
- ii. Sends alerts and notifications to users via the web interface.
- iii. Gives live status updates to be shown on the web application.

Module 4: Reporting

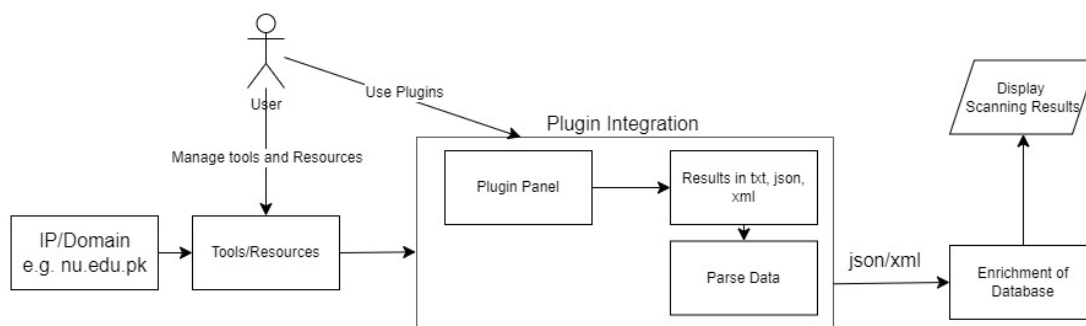
This module generates detailed reports based on the analysis and risk assessment data. The reports include vulnerability details, risk scores, and an executive summary of the organization's security posture. Graphical representations, such as bar charts, pie charts, and heat maps, are used to visualize the results. Users can export the reports in PDF format for documentation and compliance purposes.

Communications:

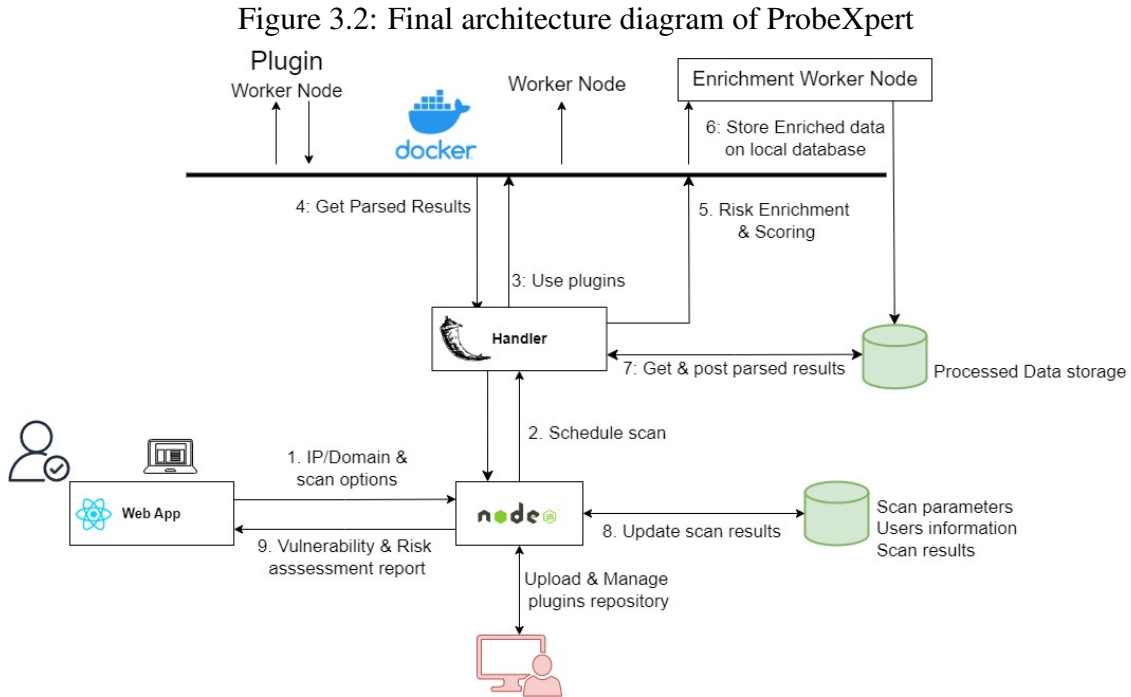
- i. Retrieves enriched data and risk scores from the Risk Factor Calculation and Vulnerability Assessment Module.
- ii. Pulls scan and risk data from the Data Management Module for graphical visualization and report creation.
- iii. Provides the final reports to the user via the Web App, allowing for easy access and PDF export.

3.1.2 Initial Design

Figure 3.1: Initial design of ProbeXpert



3.1.3 Final Architecture Diagram

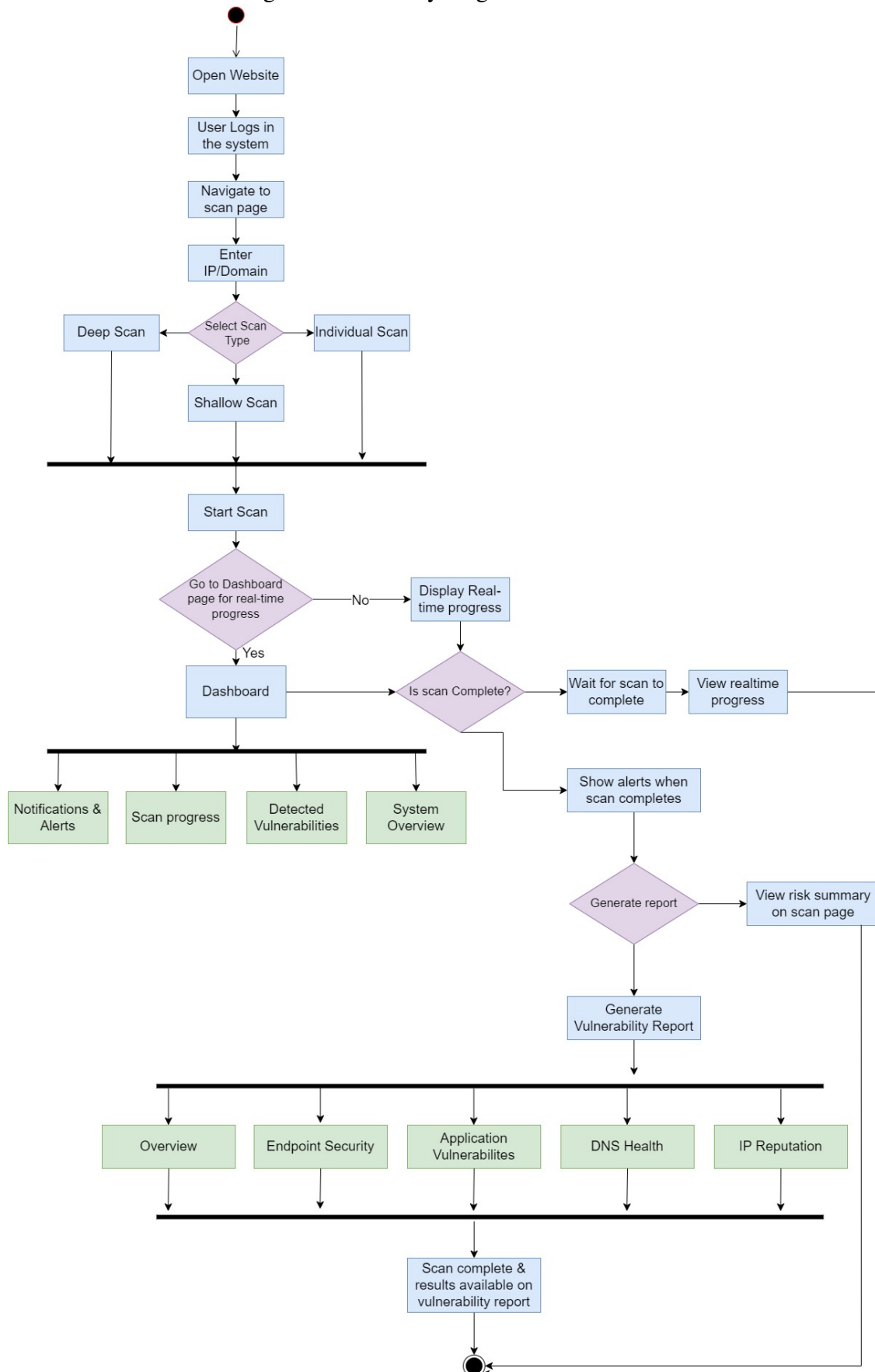


3.2 Design Models

3.2.1 Activity Diagrams

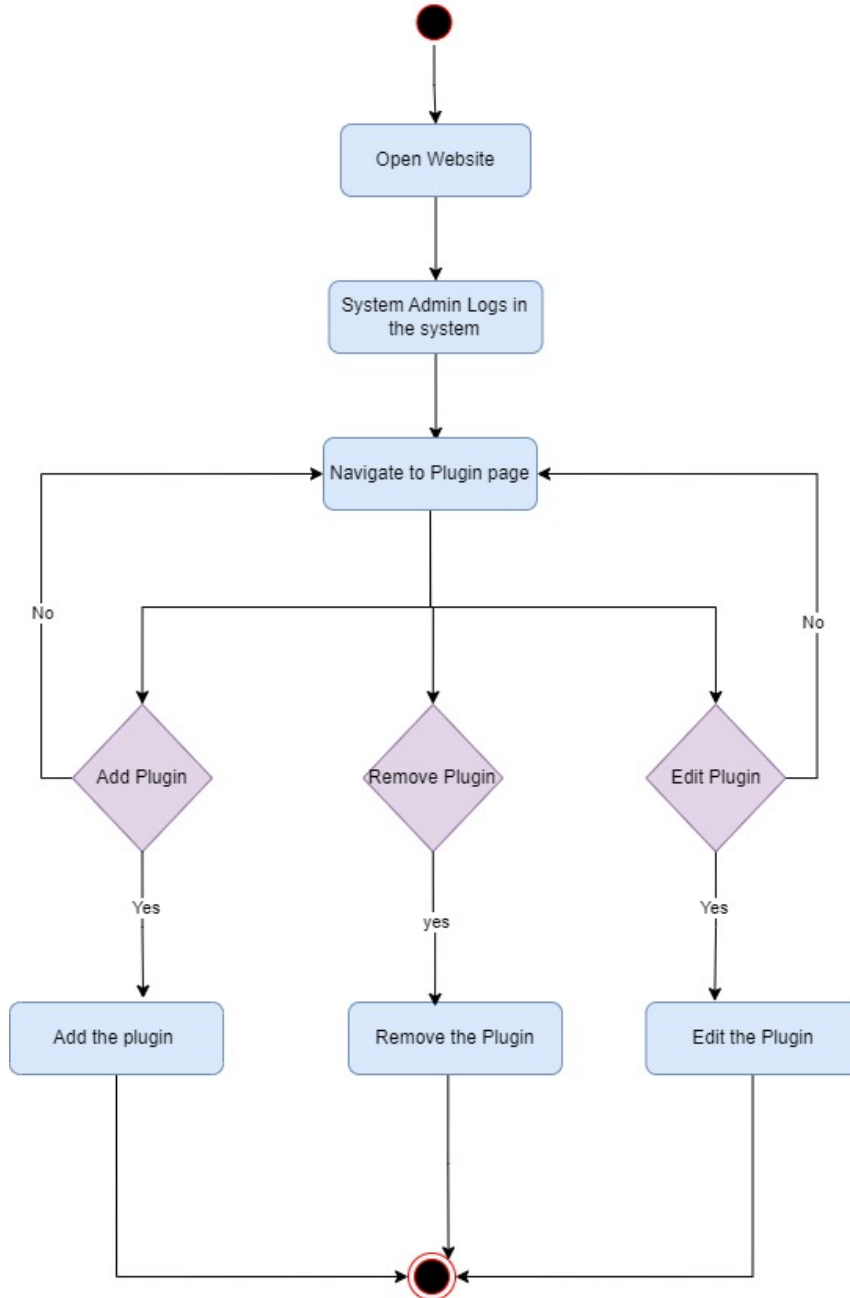
Upon accessing the website, the **End-User** logs in and navigates to the scan page where they enter an IP or domain. After selecting a scan type—Deep, Shallow, or Individual—the scan is initiated. The user can then choose to view real-time progress on the dashboard or wait for scan completion to receive notifications. Post-scan, a detailed **Vulnerability Report** is generated, categorizing findings into sections like Endpoint Security, Application Vulnerabilities, DNS Health, and IP Reputation. This report is accessible on the vulnerability report page, providing a comprehensive overview and risk summary.

Figure 3.3: Activity diagram of End-User



Upon opening the website, the **System Administrator** logs in and navigates to the plugin page. Here, they have the option to **add**, **remove**, or **edit** plugins, following decision points that lead to the respective actions based on their choices.

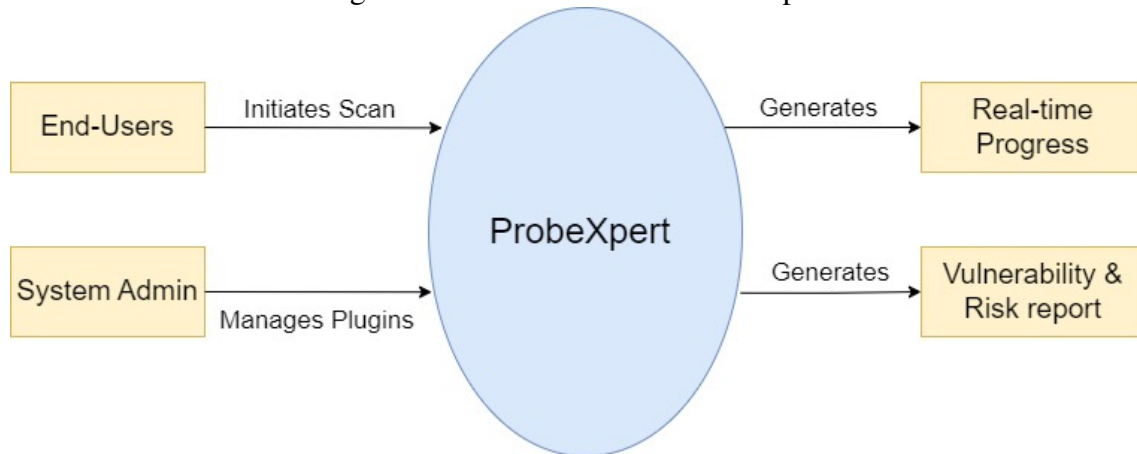
Figure 3.4: Activity diagram of System Admin



3.2.2 Data Flow Diagrams

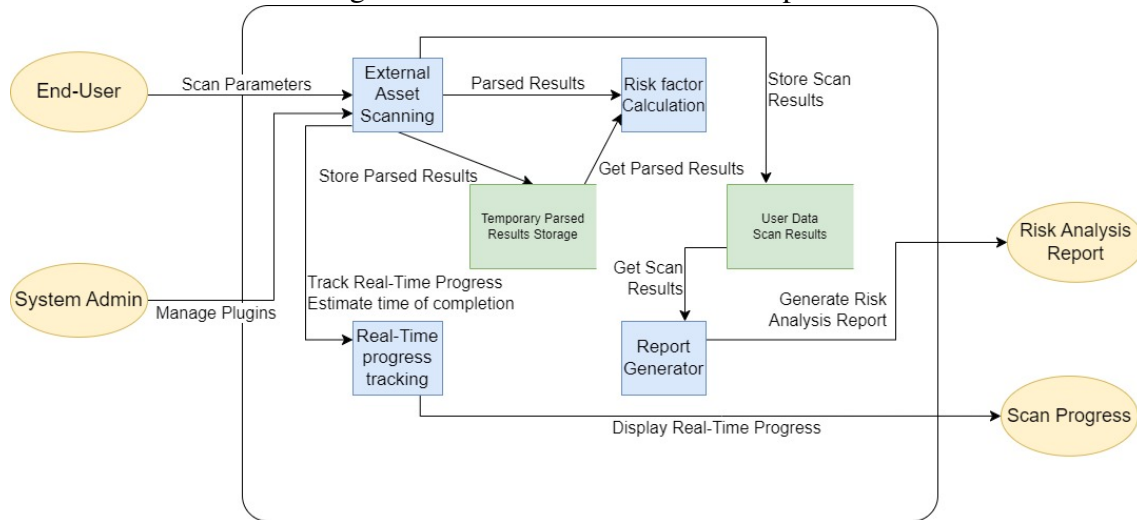
In the **ProbeXpert** system, **End-Users** initiate scans that drive real-time tracking, while the **System Administrator** manages plugins influencing the scanning process. This setup enables ProbeXpert to generate both **Real-Time Progress** updates and comprehensive **Vulnerability & Risk Reports**, centralizing control and feedback within the platform.

Figure 3.5: DFD Level-0 of ProbeXpert



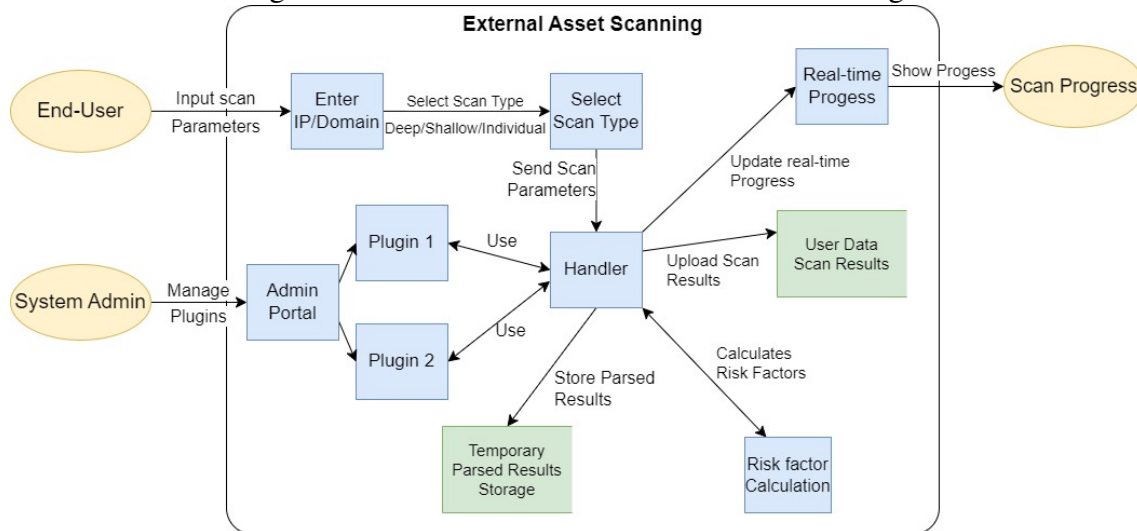
The **End-User** initiates the process by inputting **Scan Parameters**, which triggers the **External Asset Scanning**. This process yields **Parsed Results**, which are temporarily stored and subsequently utilized for **Risk Factor Calculation**. Both the **System Administrator**, managing plugins, and the scanning system track the **Real-Time Progress** and estimate completion time. The **Report Generator** accesses both parsed and scan results to produce a **Risk Analysis Report**, while also displaying scan progress to the user. This seamless flow ensures continuous monitoring and detailed reporting on the system's security status.

Figure 3.6: DFD Level-1 of ProbeXpert



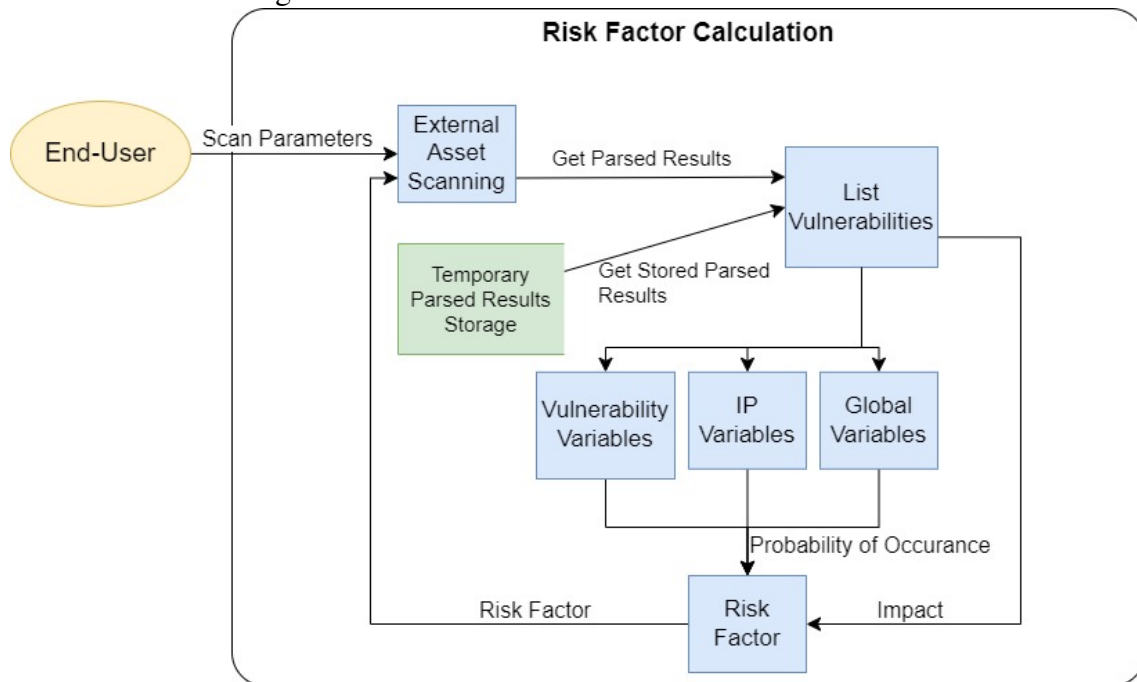
The **External Asset Scanning** process is initiated by the **End-User**, who inputs **scan parameters**, including the IP or domain, and selects the scan type (Deep, Shallow, or Individual). The system, utilizing various plugins managed by the **System Administrator** through the Admin Portal, processes these inputs. The **Handler** orchestrates the scanning, storing parsed results temporarily and updating real-time progress. These results are used for **Risk Factor Calculation** and are also displayed to the user, showing the ongoing **Scan Progress**.

Figure 3.7: DFD Level-2 of External asset scanning.



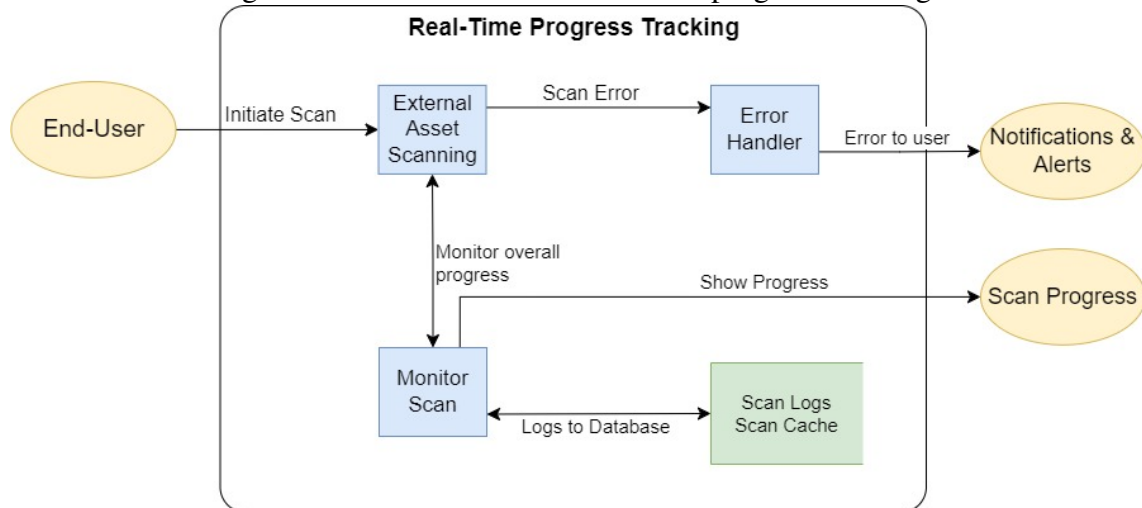
The **Risk Factor Calculation** begins when the **End-User** inputs **Scan Parameters**, triggering the **External Asset Scanning** process. This system retrieves **Parsed Results** from both the scan and the **Temporary Parsed Results Storage**. These results include a **List of Vulnerabilities**, which are then categorized into **Vulnerability Variables**, **IP Variables**, and **Global Variables**. These categories contribute to the calculation of the **Probability of Occurrence** and the **Impact** of each vulnerability, ultimately used to compute the **Risk Factor** for each identified vulnerability. This systematic approach enables precise risk assessment based on dynamic real-time data.

Figure 3.8: DFD Level-2 of Risk factor calculation.



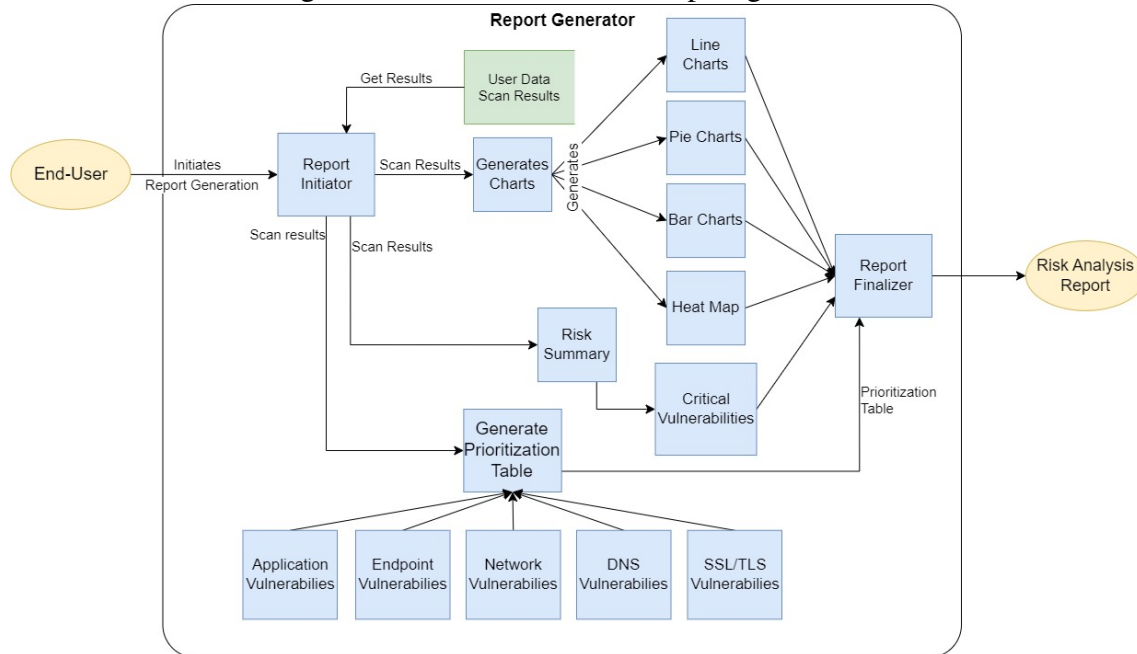
The real-time progress tracking begins with the **End-User** initiating a scan. This process is managed by the **External Asset Scanning** system, which monitors the scan's progress. If a **Scan Error** occurs, the **Error Handler** processes the error and sends a notification of the error to the user through **Notifications & Alerts**. Concurrently, the system continues to **Monitor Scan** progress, storing logs in the **Scan Logs** and **Scan Cache** database for further reference. The system displays the ongoing **Scan Progress** to the end-user, ensuring transparency and up-to-date feedback on the scanning process.

Figure 3.9: DFD Level-2 of Real-time progress tracking.



The report initiator get the stored enriched scan results from the main database and forward **generates charts** including Bar, Line, Pie chart and Heat map, **prioritization table** for risk based sorted vulnerabilities in table along with environment variables and **risk summary**.

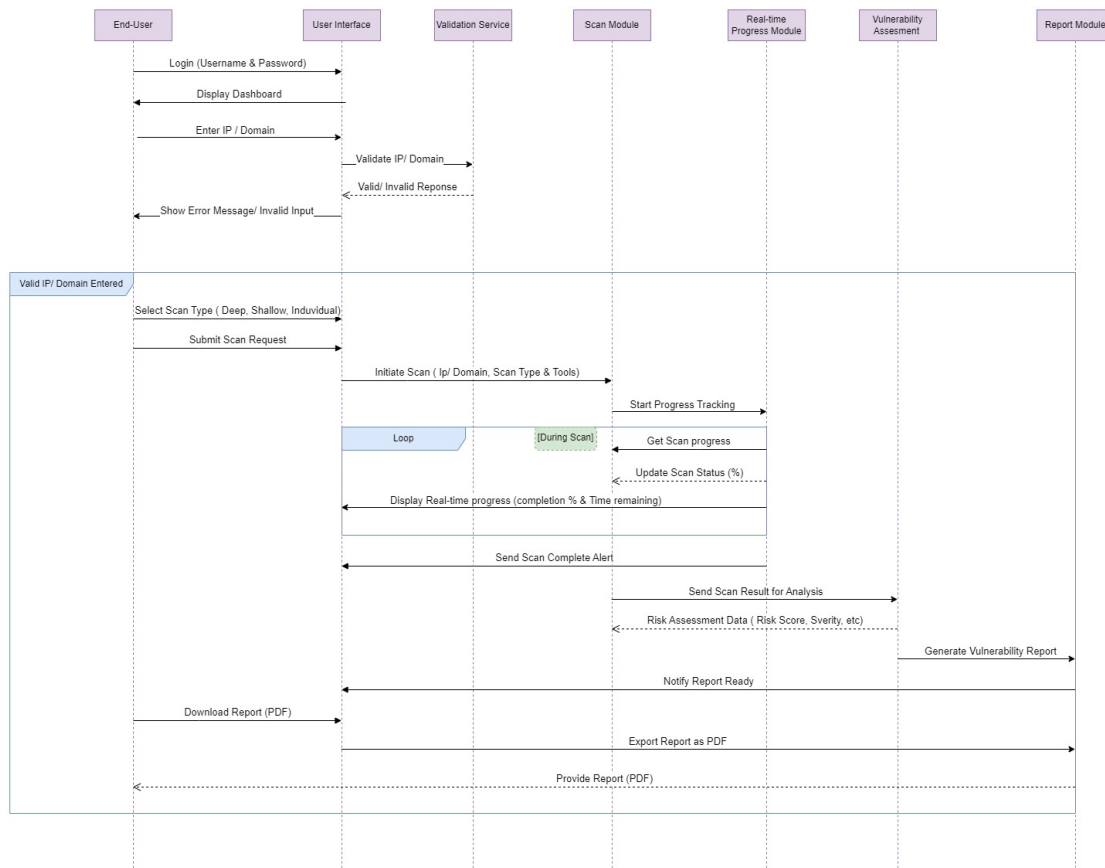
Figure 3.10: DFD Level-2 of Report generation



3.2.3 System Sequence diagrams

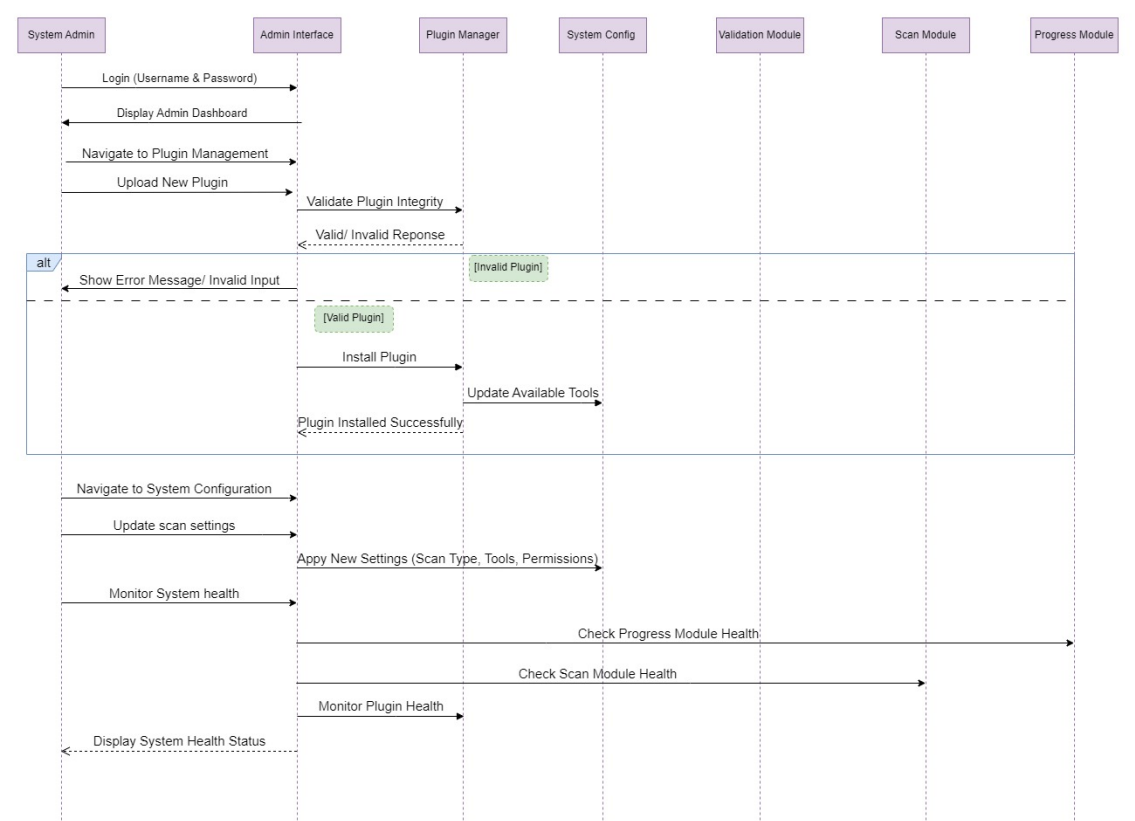
The diagram describes the end-user's interactions with the system, from login to report generation. The user logs in, enters scan parameters, and initiates a scan. The system tracks scan progress in real-time, handles scan data, and eventually generates a detailed vulnerability report, which is then provided to the user.

Figure 3.11: System sequence diagram of End-User



This sequence diagram details the interactions involving a **System Admin** within the plugin management workflow. It includes steps such as uploading, validating, and activating plugins, with conditional paths for handling errors and system configuration updates, which are integral for maintaining system integrity and performance.

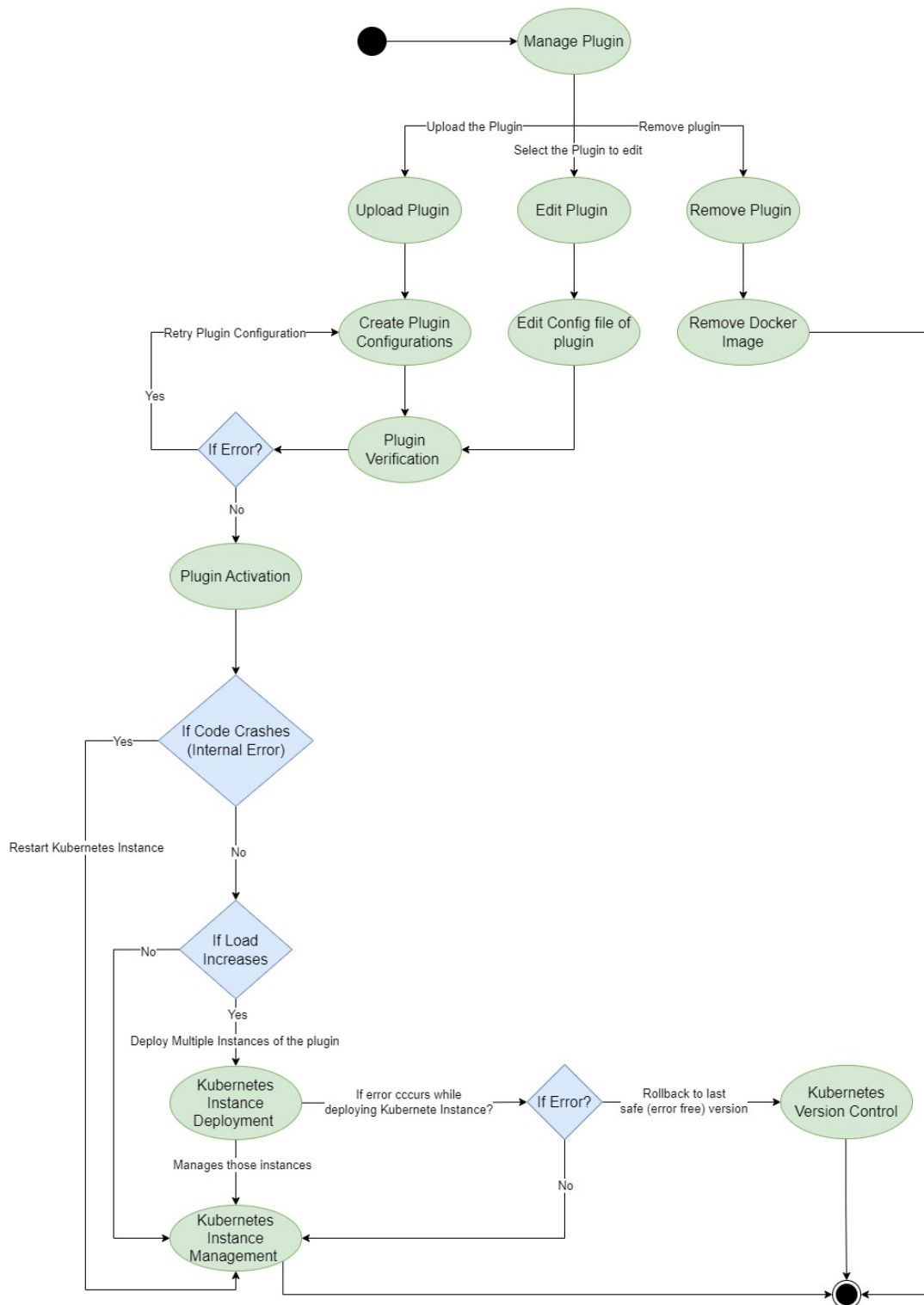
Figure 3.12: System sequence diagram of System Admin



3.2.4 State Transition Diagram

The state transition diagram illustrates the life cycle of a plugin managed by a **System Admin**, starting from upload to activation. If errors occur, the system handles them by verifying the plugin or potentially restarting Kubernetes instances, demonstrating robust error management and resource scaling capabilities.

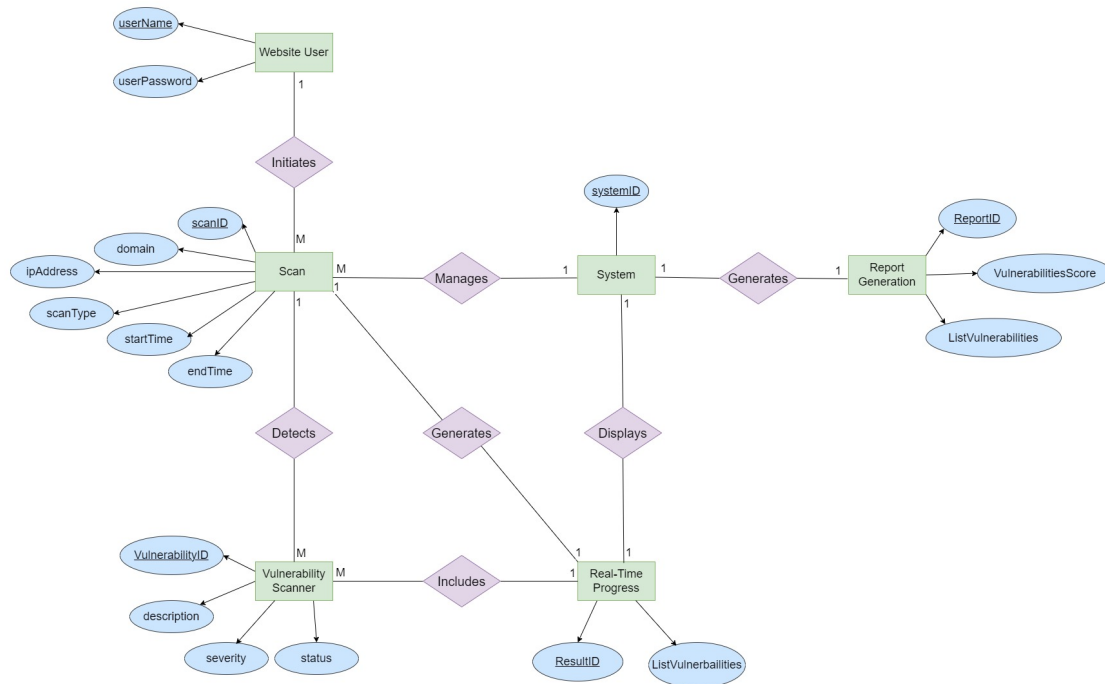
Figure 3.13: State transition diagram of ProbeXpert



3.2.5 Entity Relation Diagram (ERD) of ProbeXpert

This diagram showcases the relational structure between the **Website User**, who initiates multiple **Scans**, and the **System** that manages these scans. The **Scan** detects vulnerabilities through a **Vulnerability Scanner**, and the results are incorporated into **Real-Time Scan Results**, which are displayed by the system and used for comprehensive **Report Generation**.

Figure 3.14: Entity Relationship Diagram of ProbeXpert



3.3 Data Design

The ProbeXpert system's data organization includes converting different data entities into organized formats to make storage, processing, and retrieval more efficient. This part explains how the primary data or system entities are managed and specifies the databases or data storage items employed.

3.3.1 Information Domain Transformation

ProbeXpert handles various kinds of data, such as scan inputs and outputs, environmental variables, risk factors, user settings, and report specifications. By converting each module into structured data formats, the system can efficiently process, analyze, and store information.

3.3.2 Major Data/System Entities

i. User Inputs (IP/Domain & Scan Parameters)

- **Data Structure:** JSON format containing IP addresses, domain names, and selected scan parameters (scan type, tools, etc.).
- **Storage:** NoSQL database (e.g., MongoDB).
- **Processing:** The system stores and uses these inputs to initiate and configure scans in the External Asset Scanning Module.

ii. Scan Results:

- **Data Structure:** JSON for scan results, detailing vulnerabilities, severity levels, and metadata (e.g., scan time, IP address).
- **Storage:** Stored temporarily in NoSQL database (MongoDB) for fast querying.
- **Processing:** Retrieved by the Risk Factor Calculation & Vulnerability Assessment Module for further analysis.

iii. Vulnerability and Risk Reports:

- **Data Structure:** JSON format, containing vulnerability reports, risk scores, and prioritization details.
- **Storage:** NoSQL database (e.g., MongoDB).
- **Processing:** Used by the Reporting Module for report generation and risk visualization.

iv. Plugin Data:

- **Data Structure:** Plugin metadata, configuration files, and versions, stored in JSON format.
- **Storage:** NoSQL database (e.g., MongoDB) & Docker hub or GitLab for container images
- **Processing:** Used by the system to manage plugin updates, versioning, and rollback functionality (via Kubernetes).

3.3.3 Data Storage Items

i. NoSQL Database (MongoDB):

- **Purpose:** Stores scan results, risk scores, and real-time progress data.
- **Technology:** NoSQL databases to handle large-scale, unstructured data and ensure quick access to stored data.

Conclusion:

This report highlights the thorough and detailed work put into creating the ProbeXpert system, a strong online platform customized to address the cybersecurity requirements of SMEs. ProbeXpert simplifies cybersecurity management in resource-constrained environments by seamlessly incorporating advanced modules for external asset scanning, risk factor calculation, real-time progress tracking, and detailed reporting. The system's structure, created to be scalable and dependable, utilizes contemporary technologies like Kubernetes and Docker to guarantee effectiveness and safety. This shows ProbeXpert's ability to improve security operations and reinforces its importance as a key tool for empowering SMEs in combating advancing cyber threats.

Bibliography

- [1] J. Reyes, W. Fuertes, P. Arévalo, and M. Macas. An environment-specific prioritization model for information-security vulnerabilities based on risk factor analysis. *Electronics*, 11:1334, 2022.